



Obligatorisk Arbeidskrav 1

Emne 2 - Vår 2026

Arbeidskravformat: Individuelt

Språk: Norsk eller engelsk

Sidebegrensning: maks 12 sider. Dette inkluderer tekst, skjermbilder eller andre figurer og tabeller. Listen over brukte referanser kommer i tillegg til dette.

Filformat: .docx eller PDF-fil.

Hjelpemidler: Alle hjelpemidler er tillatt - inkludert pensumlitteratur, forelesningsnotater og praktiske oppgaver fra kurset. Hvis du ønsker å bruke en standard eller rammeverk som er brukt i forelesningen (f.eks. NIST CSF 2.0, ISO27001 eller lignende), er det fritt fram å bruke og sitere det som en bok.

Viktig: Når det gjelder sitering av pensumboken vår, referer til side(ne). For lysbildene, referer til hvilken forelesning og hvilket lysbilde-nummer (lysbilde-nummer tilsvarer sidennummer som vises i PDF-leseren din).

Karakterskala: A - F, der A er beste karakter, E er laveste bestått karakter, og F er ikke bestått.

Vekting: 50% av sluttkarakteren.

Erklæring om bruk av AI

Erklæringen om bruk av AI-verktøy og ressurser (siste side av oppgavebeskrivelsen) må fylles ut og plasseres før besvarelsen i rapporten. Denne siden teller ikke som en del av 12-siders grensen. Du finner skjemaet til slutt i denne filen (siste side).

Dette arbeidskravet har tre oppgaver.

Oppgave A er obligatorisk. Deretter kan du velge praktisk oppgave B **ELLER** besvare oppgave C. Oppgave A er 70% av karakteren, B og C er begge 30%. Hvis du velger å fullføre alle tre oppgavene, vil jeg kun sensurere A og B. C blir i dette tilfellet ikke vurdert.

1. Casebeskrivelse

NordElektro AS Digital transformasjon 2026

Du jobber som **junior informasjonssikkerhetskonsulent** for NordElektro AS i Norge. NordElektro er en av de største elektronikkforhandlerne i Norden og driver mange fysiske butikker over hele Norge, Sverige, Danmark og Finland, i tillegg til en veletablert nettbutikk. Selskapet har flere tusen ansatte som jobber i detaljhandelsbutikker, logistikk og lager, kundeservice, administrasjon og IT-drift. NordElektros forretningsmodell er avhengig av høy tilgjengelighet av digitale systemer, spesielt i perioder med høy aktivitet som kampanjer, helger og sesongbasert salg. NordElektro er sterkt avhengig av informasjonssystemer for å støtte sin daglige drift.

Fysiske butikker er avhengige av kassasystemer for å behandle betalinger og få tilgang til pris- og lagerinformasjon. Sentrale systemer håndterer lagerstyring, logistikk, leverandørkoordinering og prisoppdateringer på tvers av alle butikker. I tillegg behandler og lagrer NordElektro store mengder kundedata, inkludert personlig informasjon, kjøpshistorikk, garantidata og serviceforespørsler. Interne systemer brukes også til HR, økonomi og intern kommunikasjon. Disse systemene driftes på en kombinasjon av Linux- og Windows-servere og er koblet sammen gjennom et omfattende nettverk av infrastruktur som forbinder butikker, lagre og sentrale IT-systemer.

I løpet av det siste året har NordElektro opplevd flere operasjonelle og sikkerhetsrelaterte utfordringer. I perioder med høy aktivitet har noen sentrale systemer blitt trege eller utilgjengelige, noe som har resultert i forsinkelser ved kassene i fysiske butikker og mislykkede eller forsinkede nettbestillinger. I noen tilfeller har butikker midlertidig ikke kunnet selge produkter fordi systemene ikke svarte. Disse hendelsene har skapt frustrasjon blant kunder og butikkansatte og ført til direkte økonomiske tap. I flere av disse situasjonene ble hendelser oppdaget sent. IT-driftspersonell ble ofte først oppmerksomme på problemer etter at butikkansatte eller kunder hadde rapportert problemer. Selv om systemlogger eksisterte, ble de ikke aktivt overvåket, og det var ingen tydelig oversikt over hvilke varsler som skulle utløse umiddelbar handling.

Som et resultat ble hendelser håndtert reaktivt i stedet for proaktivt. En annen utfordring som ble identifisert av ledelsen, var uklar ansvarsfordeling under hendelser. Når systemer var utilgjengelige, var det ikke alltid klart hvem som hadde myndighet til å ta beslutninger, hvem som skulle kommunisere med butikksjefer, eller hvem som var ansvarlig for å dokumentere

hendelsen og sikre oppfølgingstiltak. Dette førte til forsinkelser, inkonsistente responser og begrenset læring fra tidligere hendelser.

NordElektro utfører også regelmessige sikkerhetskopier av kritiske systemer. Ledelsen har imidlertid identifisert svakheter i praksis for sikkerhetskopiering og gjenoppretting. Gjenopprettingsprosedyrer er dårlig dokumentert, gjenoppretting av sikkerhetskopier testes sjelden, og noen ansatte er usikre på hvor lang tid det ville tatt å gjenopprette kritiske systemer i tilfelle en alvorlig hendelse. Denne usikkerheten skaper en risiko for forretningskontinuitet, spesielt hvis et større brudd eller en sikkerhetsincident skulle inntreffe. På grunn av disse utfordringene er NordElektros ledelse i Norge bekymret for at en større sikkerhetsincident eller langvarig systembrudd kan påvirke forretningsdriften, kundetilliten og overholdelsen av lovkrav betydelig.

For å møte disse utfordringene har NordElektro Norge besluttet å styrke sin informasjonssikkerhetsholdning ved å bruke strukturerte metoder og beste praksis fra informasjonssikkerhetsfeltet. Dette omfattende sikkerhetsmoderniseringsprosjektet kalles "The Digital Shield." Etter implementeringen av Digital sikkerhetsloven (NIS2) går NordElektro Norge over fra en tradisjonell IT-sikkerhetsmodell til en proaktiv, risikobasert tilnærming ved bruk av den nyeste versjonen av NIST Cybersecurity Framework (CSF). Prosjektet innebærer oppgradering av 400+ fysiske butikker med nye skybaserte kassasystemer (Point-of-Sale, POS), en sentralisert kundestyringsplattform og en modernisert nettbutikk.

2. Oppgaver

Oppgave A (70%) -- Denne oppgaven er obligatorisk.

Oppgave A.1

For å overholde NIS2-direktivet må NordElektro ta i bruk en omfattende strategi for styring av cybersikkerhetsrisiko. Gå gjennom hver av kjernefunksjonene i den nyeste versjonen av **NIST CSF** og forklar hvordan de spesifikt skal anvendes på NordElektros nye detaljhandelsmiljø. Ditt svar skal adressere:

- Hvordan vil NordElektro etablere sin cybersikkerhet "Sikkerhetskultur"? Diskuter viktigheten av å definere roller (Ansvarlighet vs. Ansvar) og håndtere forsyningskjederisiko for deres skybaserte betalingsleverandører.
- Hvordan vil selskapet kartlegge sine kritiske verdier (kundedata, POS-maskinvare)? Diskuter rollen til risikovurdering (f.eks. sannsynlighet x konsekvens) i prioriteringen av disse verdiene.
- Hvilke tekniske sikkerhetstiltak er nødvendige for å beskytte "CIA-triaden"? Fokuser på sikkerhetsbevissthetstrening for butikkmedarbeidere og bruk av datasikkerhetstiltak som kryptering.
- Hvordan kan NordElektro implementere "Kontinuerlig overvåking" for å finne uautorisert trafikk eller uautoriserte enheter i en travel storbutikk?
- Beskriv trinnene NordElektro må ta når et potensielt brudd oppdages for å møte NIS2-kravet om rask hendelsesrapportering.
- Hvordan sikrer selskapet forretningskontinuitet slik at butikkene kan fortsette å selge produkter selv etter et større systembrudd?

Oppgave A.2

NordElektros digitale transformasjon er sterkt avhengig av å bevege seg bort fra en tradisjonell nettverksperimeter mot en Zero Trust-arkitektur. Du har fått i oppgave å designe tilgangskontrolllogikken for den nye sentraliserte styringsplattformen. Gi en detaljert analyse og anbefaling for NordElektros IAM-oppsett. Hva må være på plass for å innføre IAM basert på dette scenariet? I ditt svar, sammenlign RBAC (Role-Based Access Control) og ABAC

(Attribute-Based Access Control) modellene. Forklar hvorfor en "deltids lagerarbeider" bør ha andre tilgangsrettigheter enn en "Regional butikksjef", med spesifikt fokus på prinsippet om minste privilegium. Videre, diskuter hvordan "kontekst" (som den ansattes plassering, tidspunkt på dagen eller helsen til enheten deres) bør påvirke om en pålogging er tillatt. Til slutt, velg 3 av OWASPs topp 10 (se <https://owasp.org/Top10/2025/>) og forklar hvordan effektiv identitetsstyring fungerer som et primært forsvar mot uautorisert privilegieeskalering basert på bruksområdet.

Oppgave A.3

NordElektro Norge AS har satt et strategisk mål om å oppnå **ISO/IEC 27001:2022** sertifisering for å demonstrere sin forpliktelse til internasjonale sikkerhetsstandarder. Som en del av denne overgangen går selskapet bort fra ad-hoc sikkerhetsflikker mot et formelt informasjonssikkerhetsstyringssystem (ISMS). Et kritisk krav i ISO 27001 (spesifikt vedlegg A.5.9 og A.8) er systematisk identifikasjon av verdier og vurdering av risikoer basert på samspillet mellom spesifikke trusler og sårbarheter. Du har fått i oppgave å lede risikovurderingen for det nye "Click & Collect"-systemet, og sikre at prosessen følger en standardisert, reproducerbar vei som tilfredsstiller både ISO-krav og **NIS2-direktivet**.

Oppgave A.3.1

Grunnlaget for ethvert ISMS er en klar forståelse av hva som må beskyttes. I henhold til ISO 27001 må NordElektro opprettholde et informasjonsverdiregister (IAR). Du må begynne med å identifisere og klassifisere verdiene som er involvert i Click & Collect-prosessen. Identifiser minst to eksempler for hver av følgende kategorier: Informasjonsverdier (f.eks. personidentifiserbar informasjon (PII) om kunder eller transaksjonslogger), Støtteverdier (f.eks. skybaserte SQL-databaser eller fysiske POS-terminaler) og Immaterielle verdier (f.eks. merkevarerenomme eller kundetillit). For hver verdi må du tildele en verdieier. Forklar hvorfor tildeling av en spesifikk eier - i stedet for IT-avdelingen som helhet - er avgjørende for ansvarlighet og hvordan dette støtter "Govern"-funksjonen i NIST CSF 2.0.

Oppgave A.3.2

En risiko eksisterer bare når en trussel (en potensiell årsak til en uønsket hendelse) kan utnytte en sårbarhet (en svakhet i en verdi eller kontroll). For denne deloppgaven, fokuser på verdien "SQL-database for kunder". Identifiser en spesifikk sårbarhet (som utdaterte programvareprotokoller eller utilstrekkelig inputvalidering - med referanse til NSM Topp 10 #7) og en tilsvarende trusselsaktør (som en ekstern cyberkriminell eller en misfornøyd intern ansatt). Beskriv et detaljert trusselscenario der disse to elementene møtes og resulterer i en

hendelse. Evaluer dette scenariet mot CIA-triaden, og forklar nøyaktig hvordan det vil påvirke konfidensialiteten (datalekkasje), integriteten (datamanipulering) og tilgjengeligheten (systemnedetid) til NordElektros tjenester.

Oppgave B (30%) -- Du kan velge denne oppgaven, eller oppgave C.

Sikkerheten til NordElektros data avhenger av riktig bruk av kryptografi. Du må definere en policy for data i hvile og data i transitt for følgende tre datatyper lagret i den sentraliserte databasen: Brukerpassord, norske personnummer og transaksjonshistorikk.

1. Data i hvile: Forklar den tekniske nødvendigheten av å bruke enveis hashing med salt (f.eks. Bcrypt eller PBKDF2) for passord versus reversibel symmetrisk kryptering (f.eks. AES-256-GCM) for personnummer. Diskuter hvorfor hashing er den eneste akseptable metoden for passordlagring og hvordan AES-GCM gir "Autentisert kryptering".
2. Data i transitt: NordElektro har som mål å bruke TLS 1.3 for all kommunikasjon. Analyser to spesifikke sikkerhetsfordeler ved TLS 1.3 sammenlignet med forgjengerne, for eksempel reduksjonen i støttede cipher-pakker til moderne algoritmer som ChaCha20-Poly1305 eller AES-GCM, og eliminering av sårbare legacy-handshakes.
3. Fremtidssikring: Definer konseptet Perfect Forward Secrecy (PFS). Forklar hvordan bruk av ECDHE (Elliptic Curve Diffie Hellman Ephemeral) for nøkkelutveksling sikrer at selv om NordElektros langsiktige private servernøkkel blir kompromittert i fremtiden, forblir tidligere registrerte kommunikasjoner kryptert og beskyttet.

Oppgave C (30%) - Du kan velge denne oppgaven, eller oppgave B.

Oppgave C.1

Basert på dine trusselscenarier i **A.3.2**, må de prioriteres. Bruk DREAD-metodikken for å utføre en kvantitativ vurdering av scenariet "SQL Injection som resulterer i et databrudd". Tildel en poengsum fra 1 til 5 for hver kategori: Damage (alvorlighetsgraden av påvirkningen), Reproducibility (hvor lett angrepet kan gjentas), Exploitability (den tekniske vanskelighetsgraden), Affected Users (omfanget av påvirkningen) og Discoverability (hvor lett feilen kan finnes). Du må gi en klar, evidensbasert begrunnelse for hver poengsum. Beregn totalverdien (av 25) og plasser den i en risikomatrise for å avgjøre om risikonivået er lavt, middels eller høyt.

DREAD-kategori	Poengsum (1-5)	Begrunnelse (Detaljert forklaring)
Damage		
Reproducibility		
Exploitability		
Affected Users		
Discoverability		
Totalpoeng	/25	

Viktig: For alle oppgaver, bruk informasjon fra lysbildene og pensumbøkene. Referer til lysbildet/siden der du har funnet informasjon for ditt løsningsforslag i samsvar med de formelle kravene nevnt på første side av eksamen.

3. AI-erklæring

Kopier dette inn i din besvarelse og fyll det ut. Marker med fet skrift hva som gjelder (Ja/Nei):

Erklæring om bruk av AI-verktøy og ressurser

Sjekklisten nedenfor må fylles ut:

- **Tekstkorrigering:** Har deler av teksten blitt kontrollert ved hjelp av verktøy som Grammarly, Ginger, LanguageTool eller lignende? Ja / Nei
- **Tekstgenerering:** Har deler av teksten blitt generert ved hjelp av verktøy som ChatGPT, Jasper, WriteSonic eller lignende? Ja / Nei
- **Skrivehjelp:** Har noen ideer eller tilnærminger i rapporten blitt foreslått av verktøy som ChatGPT, Google Bard eller lignende? Ja / Nei
- **Bildegenerering:** Har noen bilder/figurer i rapporten blitt generert ved hjelp av verktøy som Midjourney, DALL-E eller lignende? Ja / Nei
- **Andre AI-verktøy:** Har du brukt andre AI-verktøy? Hvis ja, vennligst spesifiser her:

Har du brukt noen AI-baserte verktøy eller ressurser i utarbeidelsen av denne rapporten?

Hvis ja, spesifiser verktøyet og dets formål nedenfor.

1. **Tekstgenerering** -- Hvis du brukte tekstbaserte verktøy, hvilke oppgaver ble fullført med AI-assistanse, og hvordan?
2. **Bilder og figurer** -- Hvis du brukte bilde-/figurgeneratorer, hvilke bilder eller diagrammer ble AI-generert?

Jeg erklærer at all bruk av AI-verktøy eller ressurser har blitt tydelig oppgitt enten i rapporten eller i dette erklæringsskjemaet.

Kandidatnummer / Dato